Netwerk- & Communicatiebeveiligingsbeleid

ISO 27001:2022 — A.8.20, A.8.21, A.8.22

Documentnummer	ISMS-032
Versie	1.0
Classificatie	Vertrouwelijk
Eigenaar	[Naam IT-beheer / CISO]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ]

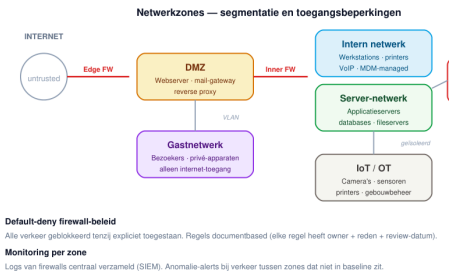
1. Doel

Dit beleid beschrijft de maatregelen voor het beveiligen van het netwerk, netwerkdiensten en de communicatie-infrastructuur van [Organisatienaam].

2. Netwerkarchitectuur

2.1 Netwerksegmentatie (A.8.22)

Het netwerk is onderverdeeld in de volgende zones:



Zone	Beschrijving	Voorbeelden	Toegangsbeperking
DMZ	Publiek toegankelijke diensten	Webserver, e-mailgateway	Sterk beperkt; geen directe toegang tot intern netwerk
Intern netwerk	Kantoorapparatuur en werkstations	Werkstations, printers, telefonie	Alleen bedrijfsapparaten
Servernetwerk	Interne servers en databases	Applicatieservers, fileservers, databases	Alleen beheerders + applicatieverkeer
Beheernetwerk	Netwerkbeheer en systeembeheer	Beheerinterfaces, jump servers	Alleen IT-beheerders met privileged accounts
Gastnetwerk	Bezoekers en externe apparaten	Gastlaptops, privételefoons	Alleen internettoegang, geen toegang tot intern netwerk
IoT/OT netwerk	Apparaten zonder volledige beveiliging	Printers, camera's, sensoren	Geïsoleerd van overige netwerken

2.2 Firewall-regels

Principe	Beschrijving
Default deny	Alle verkeer is geblokkeerd tenzij expliciet toegestaan
Minst nodige toegang	Alleen noodzakelijke poorten, protocollen en IP-adressen openstellen
Geen any-any regels	Geen "allow all" regels in productie
Documentatie	Elke firewallregel is gedocumenteerd met reden, eigenaar en reviewdatum
Review	Firewallregels worden halfjaarlijks gereviewed; ongebruikte regels worden verwijderd

3. Netwerkbeveiliging (A.8.20)

3.1 Technische maatregelen

Maatregel	Status	Beschrijving
Firewall (next-gen)	[Actief/ Gepland]	Inspectie van netwerkverkeer, IDS/IPS-functionaliteit
VPN	[Actief/ Gepland]	Versleutelde verbinding voor remote access (IPSec/ WireGuard)
DNS-filtering	[Actief/ Gepland]	Blokkering van bekende malware-domeinen en phishing-sites

NAC (Network Access Control)	[Actief/ Gepland]	Alleen geautoriseerde apparaten krijgen netwerktoegang
Wi-Fi beveiliging	[Actief/ Gepland]	WPA3 (of WPA2-Enterprise) met sterke wachtwoorden
IDS/IPS	[Actief/ Gepland]	Detectie en preventie van inbraakpogingen
E-mailgateway	[Actief/ Gepland]	Spam-, phishing- en malwarefiltering op inkomende e-mail

3.2 Draadloos netwerk

Eis	Beschrijving
Encryptie	WPA3 of WPA2-Enterprise; WEP en open netwerken zijn verboden
Scheiding	Gastnetwerk volledig gescheiden van bedrijfsnetwerk (eigen VLAN, eigen internetuitgang)
SSID	Bedrijfsnetwerk-SSID niet uitzenden (hidden) indien mogelijk
Authenticatie	Bedrijfsnetwerk: 802.1X of WPA2-Enterprise met individuele credentials
Gastnetwerk	Eigen wachtwoord dat periodiek wordt gewijzigd, geen toegang tot interne bronnen

4. Beveiliging van netwerkdiensten (A.8.21)

Dienst	Beveiligingsmaatregel
E-mail	SPF, DKIM, DMARC geconfigureerd; TLS verplicht
Webservices	HTTPS verplicht, HSTS ingeschakeld, WAF actief
Bestandsoverdracht	SFTP of FTPS; FTP is verboden
Remote access	VPN verplicht, MFA verplicht, sessie-time-out
DNS	DNSSEC ingeschakeld; DNS-over-HTTPS of DNS-over-TLS
Cloud-diensten	Conform Cloud Security Beleid (ISMS-026)

5. Monitoring

Wat wordt gemonitord	Methode	Alert bij
Ongebruikelijke verkeerspatronen	Firewall / IDS	Volume-anomalieën, onbekende protocollen

Verbindingen naar bekende malware-C2 servers	DNS-filtering / threat intel feeds	Elke detectie
Brute-force pogingen op netwerkdiensten	IDS/IPS	>10 pogingen in 5 minuten
Ongeautoriseerde apparaten op het netwerk	NAC / DHCP-monitoring	Elk onbekend MAC-adres
VPN-verbindingen vanuit ongebruikelijke locaties	VPN-logging	Verbinding buiten NL/BE zonder voorafgaande melding

6. Verantwoordelijkheden

Rol	Verantwoordelijkheid
IT-beheer	Implementatie, configuratie en beheer van netwerkbeveiliging
CISO	Toezicht, beleid, review van firewallregels en monitoring
Externe netwerkbeheerder (indien van toepassing)	Uitvoering conform SLA en beveiligingseisen

7. Versiebeheer

Versie	Datum	Wijziging	Auteur
1.0	[DD-MM-JJJJ]	Initiële versie	[Naam]